



21.1 Introduction to Incident Response

Overview

Today's class provides an overview of incident response (IR) and its role in the security sector. You will cover processes, plans, procedures and tools incident responders use today.

Class Objectives

By the end of today's class, you will be able to:

- Identify the types of incidents typically escalated to incident response managers.
- List the members of a SIRT and their roles.
- Identify how an incident response plan can guide the SIRT when an incident occurs.
- Use the malware testing tool, ANY.RUN, to dynamically analyze ransomware.

Slideshow

- Slides for this lesson are available on Google Drive [here](#).

01. Introduction to Incident Response

This week will introduce the exciting world of digital forensics and incident response (DFIR).

- Today's class will introduce incident response, and the next three classes will focus on digital forensics.

- Recall that various threats can negatively affect a company, such as malware, DDoS/botnet attacks, phishing, and data breaches.
 - Therefore, companies implement security systems to prevent these incidents, like system firewalls, intrusion prevention systems, network security firewalls, and application security.
- Incident response (IR) deals with situations where those security systems fail and a company is negatively affected by incidents.
 - IR is a procedure that an organization uses to react, mitigate and respond to a security problem.
 - There are always threats to an organization's system; therefore, IR is an essential element of an organization's security system.
 - For example: A company's security systems are like a bank's alarm and security guards. Threats are like bank robbers, and the incident response is like the police responding *after* the alarm went off and the robbers broke in.
 - Emphasize that incident response isn't about blocking negative actors; it's about finding them and getting them out.
- IR is a broad term. When we refer to it, we are talking about the comprehensive actions that an organization takes when a security incident occurs.

SIRT Structure

- Organizations need an organized team to respond and manage these security incidents.
 - This team is known as the security incident response team (SIRT).

While organizations structure their SIRT based on their needs, most SIRTs are typically made up of the following roles:

- security operations staff
- incident responders and incident response managers
- Aligned staff:
 - Legal
 - Compliance
 - Communications and PR
 - Engineers

Security Operations Center (SOC)

- The first responders to handle security issues work out of a Security Operation Center, often referred to as SOC.
- Ideally, these teams should work 24/7 to provide the best possible coverage for their organizations. However, this is a decision that varies by organization.
- The extent of a SOC's operating hours is just one of many high-level business decisions covered in an incident response plan.

SOC Operations Staff

SOC staff are called **SOC analysts**.

- They are often organized in a chain of command divided into three tiers.
- Tier 1 analysts (junior analysts) are the first responders and the first line of defense.
 - They are often in charge of monitoring alerts and verifying that they are not false positives.
 - They follow pre-planned procedures, perform an initial investigation, solve simple incidents, and escalate as needed.
 - Tier 1 is an entry-level role and a starting point for most students choosing this career path.
- Tier 2 analysts are the first escalation point for the Tier 1 Analysts.
 - In other words, they help get past any blockers that the Tier 1 analyst may have.
 - Tier 2 analysts can perform the duties of Tier 1 as needed but can also divert from written procedures.
 - They will also support Tier 3 as needed, create documentation and procedures for Tier 1 and monitor Tier 1 performance.
- Tier 3 analysts are the second escalation point and may serve more of a forensics or deep investigative role.
 - Tier 3 analysts often own the tools used by the IR team, oversee complex incidents, and mentor and monitor the performance of all other tiers.
- SOC managers can perform all of the duties of a Tier 3 Analyst, but they also manage the team and have the HR responsibility for growing and maintaining the team.

SOC staff's responsibilities includes determining if a security issue is considered a high priority incident that requires an incident response manager.

Determining if an incident requires escalation

SOC analysts typically receive specific directives about what type of incident requires escalation to an incident response manager.

- However, analysts often encounter unique issues that require their professional judgment.

Issues that technically, financially, or reputationally impact the entire organization typically require escalation.

- SOC analysts typically handle issues that impact single users.

Note the following example:

- *A SOC analyst determined that one employee had their account breached. The attacker obtained data of all the organization's customers.*

Would this situation would require escalation?

- Note that while only one employee was impacted, the potential larger organizational impact may require further investigation and assistance from legal, compliance, and communications teams.

In the next activity, you will discuss several scenarios to determine if they require escalation.

02. Activity: Escalate or Not?

- You are a SOC analyst for a financial services organization that has experienced multiple security issues.
- Your task is to review the following issues and whether they should be escalated to the SIRT.

[Activity File: Interpreting IR Plans](#)

03. Activity Review: Escalate or Not?

04. Incident Response Plans

Note that our first activity covered how first responders determine if a security incident requires escalation to the SIRT.

- This next section will cover what happens after the SIRT has been assigned to an incident.

Before we cover these next steps, let's cover some important terms used by the SIRT:

- A bridge, also known as a bridge call, is a conference call or communication channel where the SIRT discusses a specific security issue. It is common to set up side-bridges to discuss related issues with smaller groups. For example, a side bridge may be created with the legal and PR team to discuss legal implications and the communications process.
- Incident response plan: A formal, high-level document detailing how the organization will respond to incidents.
- Response process: A more general document, not as formal as an IR plan
- Response procedure: A step-by-step workflow for a given part of a response, often organized in a flowchart.
 - This is the document that a junior analyst would follow explicitly when responding to a given incident. Senior analysts are familiar with the expected procedure and can go beyond it.
- Incident response playbook: A collection of procedures for a given type of incident.
 - It may be split up into various procedures under different aspects of a response, such as detect and analyze, eradicate and recover, post-incident procedure, etc.
- Root cause analysis (RCA): This is a process or report that determines the root reason for the incident
- Post-incident report: A process and document designed to provide an overview of the analyst's findings and response to a particular incident
 - The analyst must produce a report for every incident that warrants a response. These reports also include steps to prevent the issue from reoccurring. Post-incident reports are also known as post-mortem reports.
- Tabletop exercise: A common exercise wherein a security team discusses, in detail, the steps they would take to respond to a given incident

SIRT first steps

We can now get into the IR process.

- A common first step by an incident response manager after escalation is to open a bridge.

This bridge is often a conference call, where all initial required teams that understand the issue will be invited.

- Next, the IR manager will have a subject matter expert explain the issue and its potential impact.
- Commonly, IR managers first determine whether the issue is a false positive before any further escalation.

Simple and Complex Incidents

- An incident response manager may not be an expert on every possible incident. It is very common to call in specific expertise to assist in the response effort.
 - For example, they may rely on an app developer to help analyze application logs before they tie in the results to the bigger picture of the incident.
- Incidents vary in complexity.
 - Simple incidents are usually opportunistic attacks that can be solved by junior analysts following specific steps. Examples include phishing attacks or malware downloads.
 - Complex incidents are more widespread or more sophisticated. They are more severe and require a more coordinated effort. These may involve multiple IR team members and/or multiple IT teams. Examples include attacks that affect multiple employees and/or servers.

The next step of incident response, regardless of complexity, is creating a plan of action. Before any response occurs, and in order for a team to effectively resolve an issue, there needs to be an **incident response plan**.

- Every company should have a plan that documents exactly when to respond, what to do, how to do it, and who is in charge of doing what.
- Organizations should also have different response plans for different incidents.
 - For example, they may have a different plan for a:
 - Data breach

- DDoS attack
- Application security vulnerability

Incident Response Plans

Incident response plans should cover the process and answer common questions.

- For example, an IR plan for a web server vulnerability could include answers to the following questions:
 - Do you immediately take it offline and just send a notification?
 - Who makes the decision to shut it down?
 - Do you need management approval to shut systems down?
 - Who needs to be notified?
 - Will it affect company revenue or customer experience?
 - When do you involve the PR department?
 - When do you involve the legal team?
 - Who communicates the issue with the executive team?
- After the plan is in place, security teams should have regular, scheduled exercises to test response plan efficiency on non-production systems. Organizations should also have regular tabletop exercises throughout the year. With each incident and exercise, the response should be evaluated and documented.
- The ability to effectively execute a plan and make these decisions can be critical to a company's bottom line:

In the next activity, you will review incident response plans from several different companies.

05. Activity: Interpreting IR Plans

- In this activity, you will compare real-world incident response plans from different companies in different sectors and industries.
- Don't be overwhelmed by the volume of these documents. Focus on each document's table of contents and choose one section to compare across documents.

[Activity File: Interpreting IR Plans](#)

06. Activity Review: Interpreting IR Plans

07. Break

08. Developing an Incident Response Plan

- Creating an incident response plan is easier when there is a standard framework to follow.

NIST Guide for Computer Security Incident Handling:

- The NIST Guide is the industry standard for incident response. It documents detailed plan and process descriptions for everything involved in an incident.
- Companies can also use the NIST standard as a framework for building their own plans, only incorporating the items that make sense for them.
- Incident response plans must be continually executed, assessed, and updated to keep up with current threats. A plan that worked well six months ago may not be equipped for today's rapidly changing threats.

An important part of an incident response plan is the incident response playbook.

- The incident response playbook is a collection of procedures for a given type of incident. It may be split into various procedures under different aspects of a response.
- Note the following common phases of an Incident Response Playbook:
 - 1. Prepare
 - 2. Detect and analyze
 - 3. Contain, eradicate and, recover
 - 4. Post-incident

- Prepare:
 - The **prepare** phase is about building and documenting the specifics of how to handle an incident. This phase also includes identifying key contacts and steps taken BEFORE any analysis takes place.
 - This phase often includes determining and documenting the following:
 - How to handle hardware and software
 - System documentation, network diagrams, baselines
 - Clean OS and application images available
 - Who is going to monitor and who is going to respond
 - Key stakeholders and their contact info
- Detect and Analyze:
 - The **detect and analyze** phase is about validating, identifying, and prioritizing the issue.
 - This phase often includes determining and completing the following:
 - System logs and IDS/IPS system alerts
 - Anti-virus software alerts
 - Host-based monitor detects configuration change
 - Network traffic anomalies
 - Characteristics and indicators of a threat
 - Business impact
 - Incident priority
- Contain, Eradicate, and Recover:
 - The **contain, eradicate, and recover** phase is about preventing the issue from worsening, removing and stopping the issue, and recovering all business capabilities.
 - This phase often includes completing the following:
 - System isolation (could be problematic)
 - Disabling breached user accounts
 - Replacing compromised files
 - Determining affected systems
 - Identifying attack tools, methods, vectors and vulnerabilities
 - Communicating with relevant teams
 - Verifying incident is removed with updated monitoring
 - Recovering affected systems or restoring from backup
 - Identifying steps to be taken on the affected servers or systems
 - Erasing systems/firewall updates/patches etc.
- Post-Incident:
 - The **post-incident** phase is about understanding the specifics of what caused the issue, how to improve future responses, and how to mitigate future issues.

- This phase often includes completing and documenting the following:
 - Learning and improving
 - Post-incident meeting
 - Reviewing detailed timestamp of events
 - Re-evaluating the incident response plan
 - Updating system alerts to make them more accurate
 - Reviewing changes
 - Updating response workflow
 - Documenting and reporting
 - It is imperative to have a playbook in place so the team knows what to do when something happens.
-

09. Responding to a Malware Incident with ANY.RUN

Many organizations are constantly concerned about malware infection.

- For example, a ransomware attack on a hospital could severely impact patient health by preventing access to medical data.

Organizations are often challenged with how to respond to incidents when a new type of malware has potentially infected their network.

- The challenges can include:
 - How and when was the user or machine infected?
 - Were any other users/machines infected?
 - What was the impact of the malware?
 - Was data exposed, modified, or deleted?

To answer these important questions, organizations must use tools to analyze the malware.

Running live malware is inherently dangerous, so security analysts must use special environments to do their jobs safely.

- They typically use two types of tools to analyze malware:
 - **Static malware analysis tools** analyze raw source code. They look for things like IP addresses (reveals C2 servers).

- **Dynamic malware analysis tools** analyze what the malware does when it runs. They look for things like Wireshark captures to identify "phoning home" (communication w/ C2 server) and suspicious changes to the file system and/or registry.

We will now learn to use a dynamic malware analysis tool called **ANY.RUN**.

ANY.RUN

- ANY.RUN is a web-based dynamic malware analysis tool.
- It provides an interactive sandbox where a security engineer can view how the malware responds to different scenarios.
- ANY.RUN can provide insights about how the organization may be impacted.
- It can show network details about how the malware communicates by identifying IP addresses and suspicious domains.

Analyzing Malware with ANY.RUN Demonstration

We will now demonstrate the ANY.RUN tool by analyzing the Adylkuzz malware.

- Adylkuzz is a cryptocurrency-mining malware, which hides in the background and uses the computer's resources to mine the digital currency, Monero.

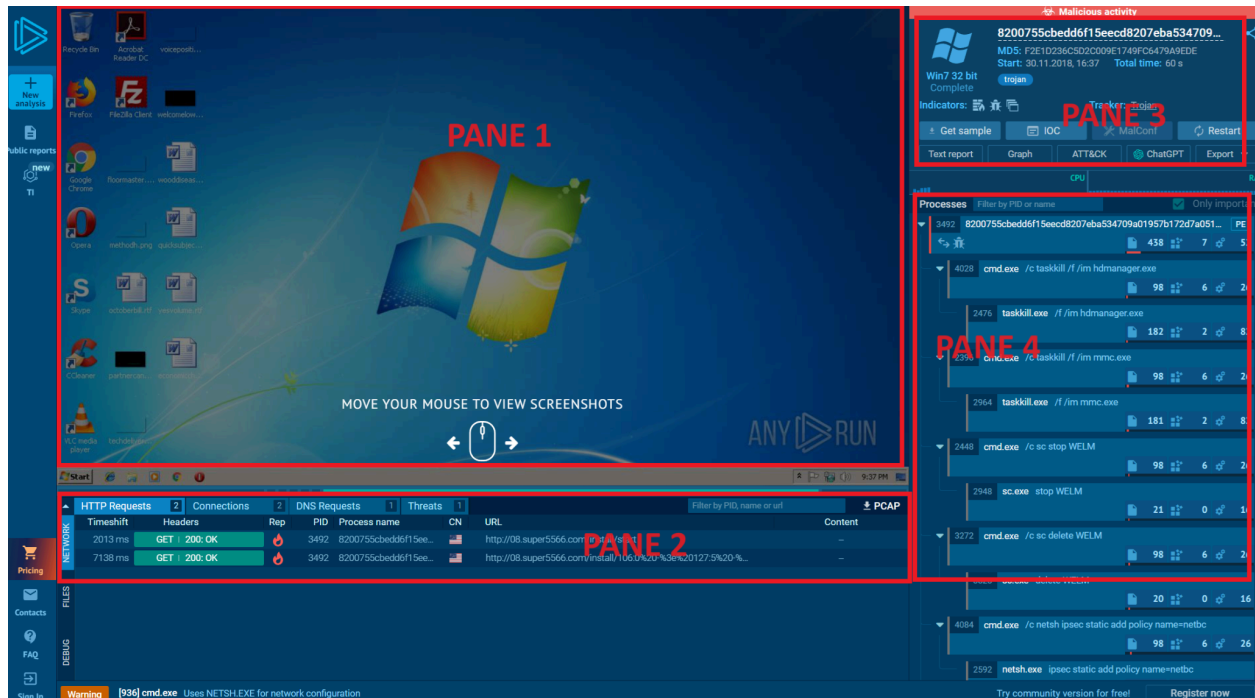
While the ANY.RUN interface is pleasantly intuitive, it contains a lot of information.

- In this walkthrough, you'll learn where all of it lives.

Open up the following page [Adylkuzz Malware on ANY.RUN](#)

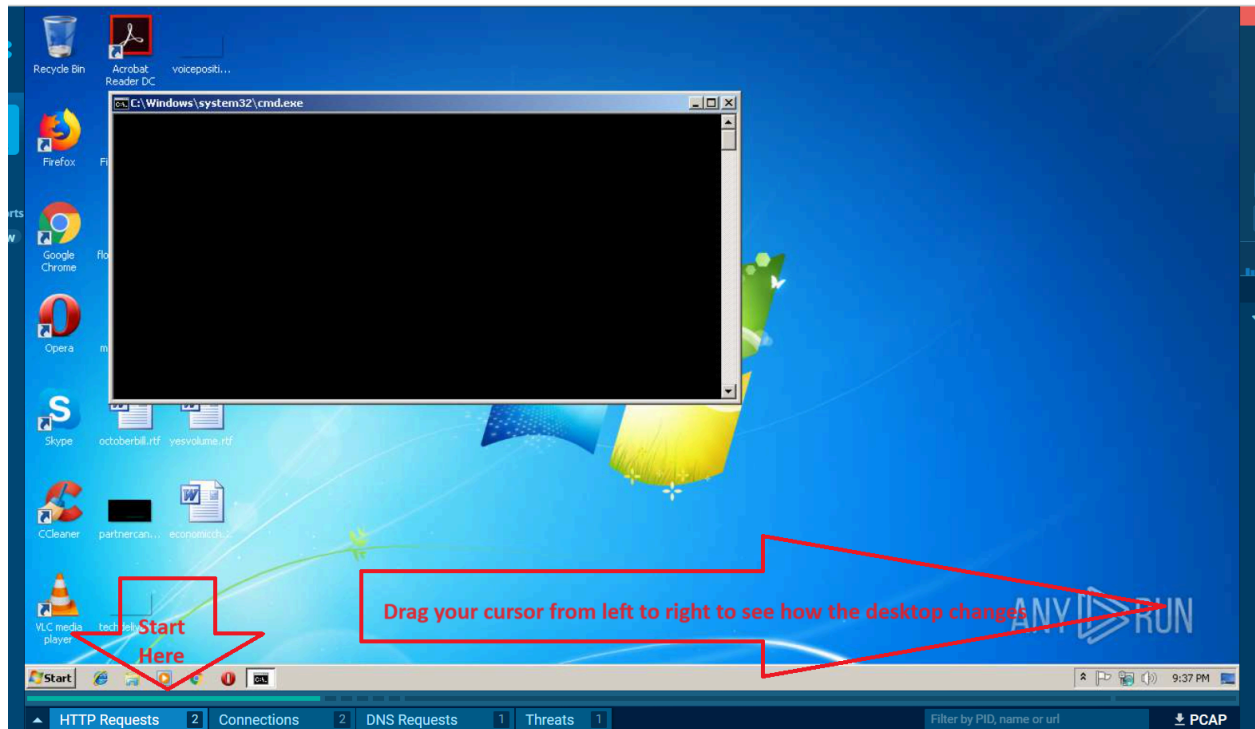
In the main UI you're first presented with, note the following four panes:

- Pane 1: The top left contains a view of the VM's desktop, which can be useful for collecting screenshots for your report.
- Pane 2: The bottom left presents a Details pane.
- Pane 3: The top right contains metadata about the malware.
- Pane 4: The bottom right contains detailed information about the VM's process environment.



Pane 1: VM Desktop

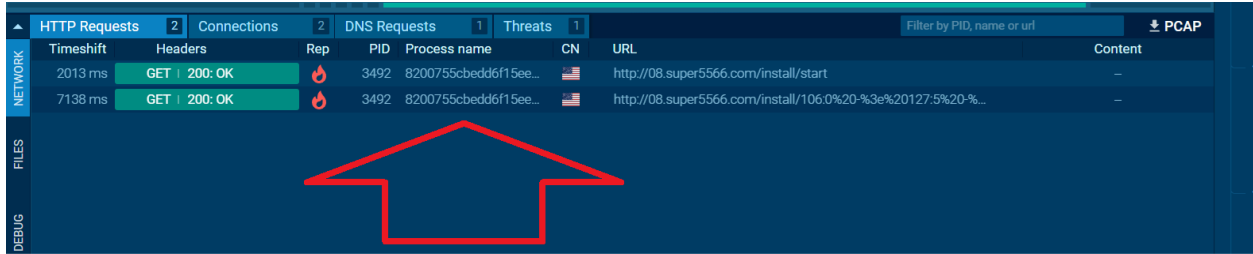
- Move your cursor across the bottom of Pane 1, and drag it from left to right. (Use the image below as guidance)
 - Explain that this shows what the desktop displays as the Malware runs.
 - While this malware does not display much on the user's desktop, you can see the command prompt appearing as the malware runs.



Pane 2: Details

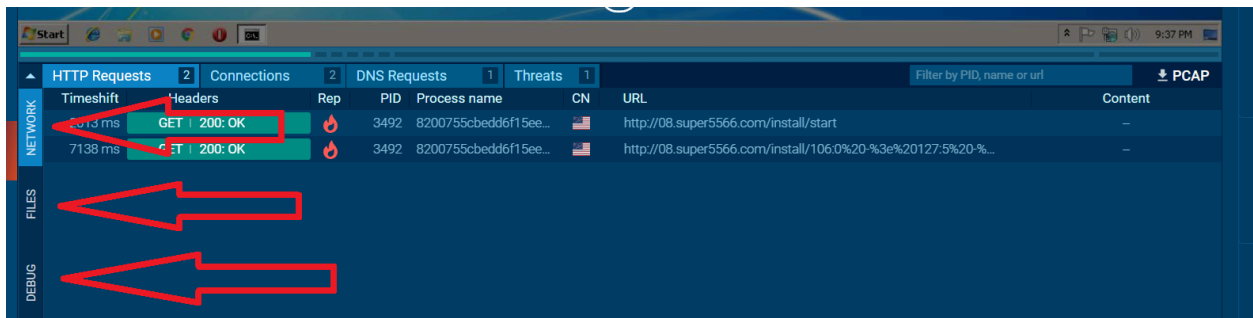
Now move to the bottom-left pane. This is the Details pane.

- Note the four columns it includes:
 - HTTP Requests: All HTTP requests made by any process running on the VM.
 - Note two HTTP requests being made, and the URLs to which they connect.
 - Connections: All connections to/from the VM.
 - These include the two HTTP requests just displayed
 - DNS Requests: All DNS requests are made by processes running on the VM.
 - Threats: Any known threats identified by ANY.RUN.



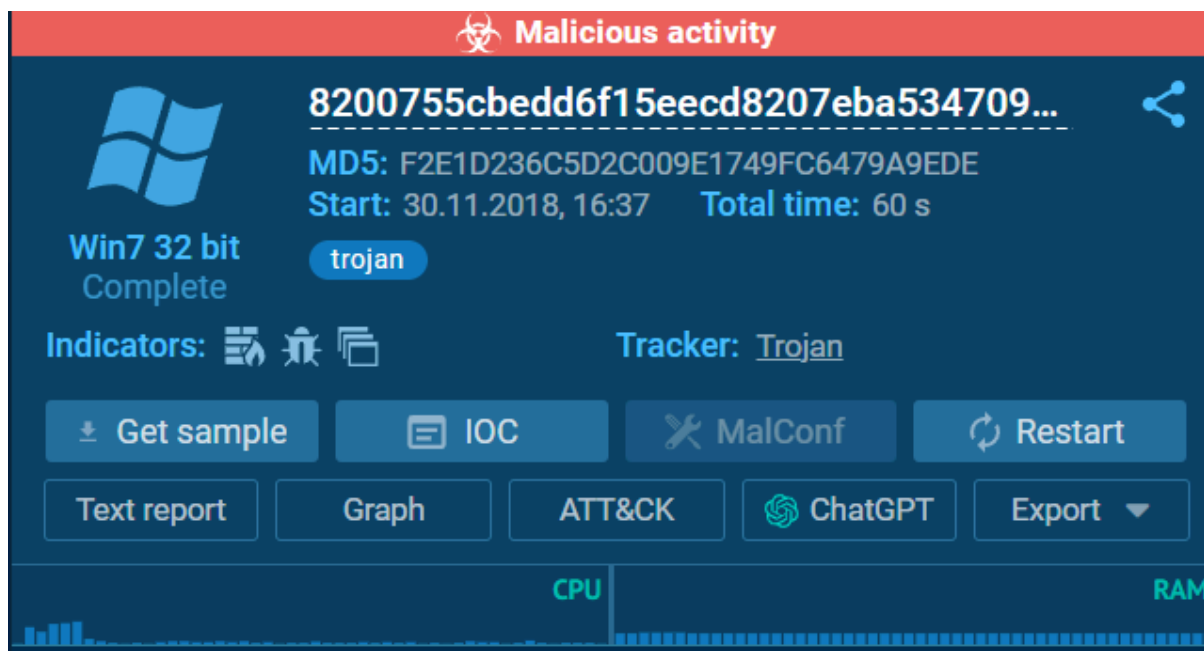
HTTP Requests 2 Connections 2 DNS Requests 1 Threats 1									
	Timeshift	Headers	Rep	PID	Process name	CN	URL	Content	
NETWORK	2013 ms	GET 200: OK	🔥	3492	8200755cbdd6f15ee...	🇺🇸	http://08.super5566.com/install/start	-	
	7138 ms	GET 200: OK	🔥	3492	8200755cbdd6f15ee...	🇺🇸	http://08.super5566.com/install/106.0%20-%3e%20127.5%20-%...	-	
FILES									
DEBUG									

- Note the three icons on the far left:
 - Network (top icon) loads the information about loads the information about HTTP requests, connections, DNS requests, and threats that you've already seen.
 - Files (middle icon) load information on any files changed by processes running on the VM.
 - Debug (bottom icon) loads Debug Output, which loads information about errors in running processes.



HTTP Requests 2 Connections 2 DNS Requests 1 Threats 1									
	Timeshift	Headers	Rep	PID	Process name	CN	URL	Content	
NETWORK	2013 ms	GET 200: OK	🔥	3492	8200755cbdd6f15ee...	🇺🇸	http://08.super5566.com/install/start	-	
	7138 ms	GET 200: OK	🔥	3492	8200755cbdd6f15ee...	🇺🇸	http://08.super5566.com/install/106.0%20-%3e%20127.5%20-%...	-	
FILES									
DEBUG									

Pane 3: Metadata



Now, move to the top right Metadata pane, and note the following important buttons:

- Info (top) provides information about the file format, hash signatures, required libraries, etc.
- IOC summarizes TCP connections, DNS requests, and HTTP requests.
- Text Report contains file information similar to that provided by the Info button.

Click on the ATT&CK button to illustrate how this feature works

- ATT&CK identifies which tactics and techniques from the Mitre Attack framework are being used in this malware.
 - Note that this malware uses the Disabling Security Feature technique.
 - This is a very useful feature to refer to.
 - Click on the "X" on the top right to return to the main page



Pane 4: Process Environment

Navigate to the Process Environment pane in the bottom-right.

- This contains a list of all processes running on the VM.

On the left half of the UI, note the following:

- Click on the first running process, and note the Process Details pane that appears.

- Click on More Info in the Process Details pane.

Processes Filter by PID or name ☒ Only important

PID	Process Name	Command Line	Private Bytes	Working Set	Session ID	Architecture
3492	8200755cbedd6f15eecd8207eba534709a01957b172d7a051...		438	7	52	PE
4028	cmd.exe	/c taskkill /f /im hdmanager.exe	98	6	26	
2476	taskkill.exe	/f /im hdmanager.exe	182	2	82	
2396	cmd.exe	/c taskkill /f /im mmc.exe	98	6	26	
2964	taskkill.exe	/f /im mmc.exe	181	2	82	

Process details ID 3492 **Malicious**

8200755cbedd6f15eecd8207eba53...

Username: admin
Start: +0ms Indicators:

100
OUT OF 100

Command line

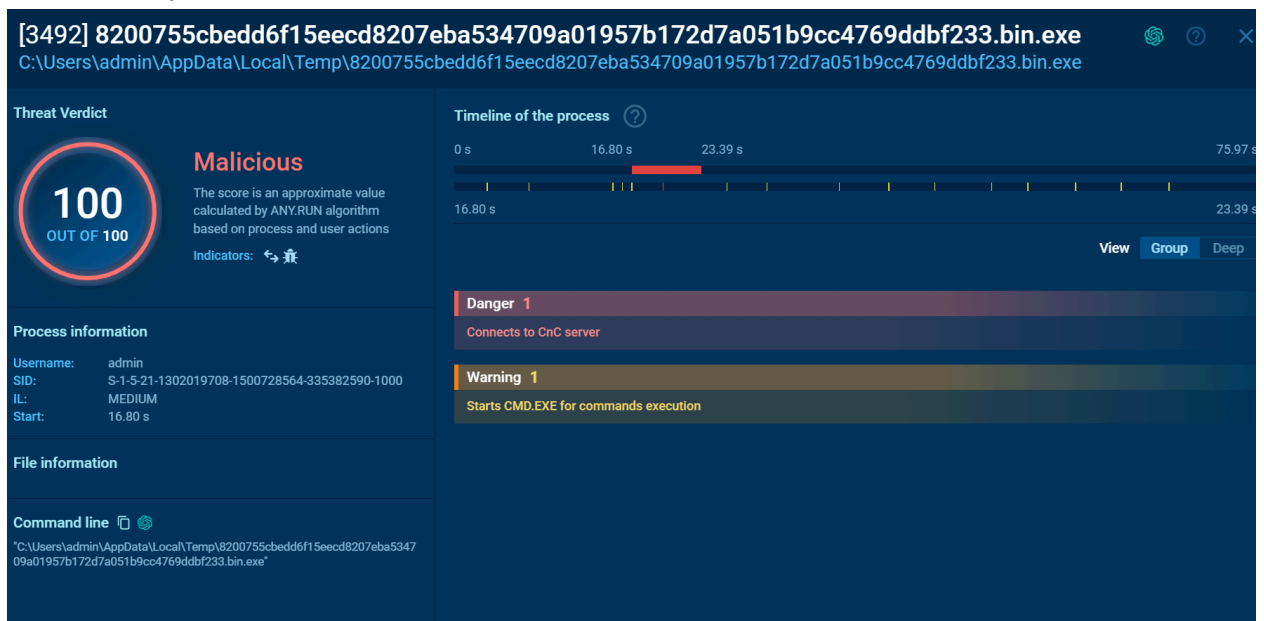
"C:\Users\admin\AppData\Local\Temp\8200755cbedd6f15eecd8207eba534709a01957b172d7a051b9cc4769ddbf233.bin.exe"

More Info

Danger 1

Connects to CnC server

- Note the following in the resulting UI:
 - The Threat Verdict that this is a malicious process.
 - This process connects to a CnC server.



Click the x in the top-right corner to return to the main UI.

In the final activity for today, you will analyze a ransomware malware using ANY.RUN.

10. Analyzing ransomware with ANY.RUN Activity

- In today's final activity, you will play the role of an incident responder tasked with analyzing a malware that infected a user's computer at your organization.
- You are tasked with safely analyzing the provided malware and completing a report about its organizational impact.

[Activity File: Analyzing ransomware with ANY.RUN](#)

11. Review: Analyzing ransomware with ANY.RUN Activity